

Documentation-Driven Threat Analysis

Authoring Rules

Through SpecializedRequirement – Revision 3

Contratto operativo di authoring e review per la documentazione governata

Research baseline source: 3eeac1fc972d89282cd2ffd8700e9af0f5b69610.

Revision feedback: chiusura S1 di *SpecializedRequirement* e regressione del corpus facial-access senza MR-0004.

Data: 14 agosto 2026.

Questa revisione estende il precedente contratto “Through Functional Requirement R2”. Non formalizza SecurityRequirement, Base Analysis, BAE o metodologie di threat analysis.

Indice

1	Scopo e principio di sufficienza	2
2	Sequenza di authoring	2
3	Step 0 – frame the project problem	2
4	MacroRequirement authoring	3
4.1	Semantica del corpo	3
4.2	Review tests	3
4.3	Isolated-MR review	3
4.4	Regression example – facial access	4
5	Decision authoring	4
5.1	Responsibility-boundary question	5
5.2	Necessity/default Decision	5
6	FunctionalRequirement authoring	5
6.1	Regole chiuse	5
6.2	Normative prose e SPO	5
6.3	Parameter classification	6
7	SpecializedRequirement authoring – S1 CLOSED	6
7.1	Core semantico minimo	6
7.2	Removal, correctness e autonomy tests	6
7.3	Shared concern non significa multi-parent SR	7
8	Cross-branch composition e effective context	7
9	End-to-end review checklist	7
10	Tool assistance	7
11	Status	8
12	Reopen rule	8
A	Traceability	8

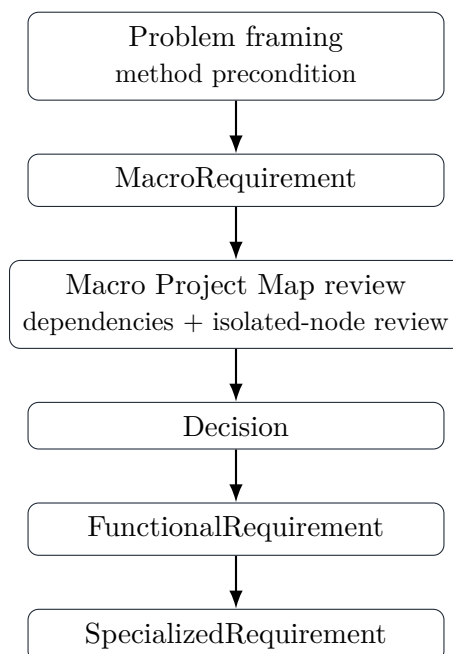
1 Scopo e principio di sufficienza

Questo documento traduce il baseline concettuale DDTA in domande di authoring e test di review ripetibili. Lo scopo non è ottenere una descrizione perfetta o completa del sistema prima dell'analisi. Lo scopo è produrre la *quantità minima sufficiente di conoscenza governata* perché responsabilità, commitment e comportamenti conosciuti siano interpretabili, revisionabili e analizzabili.

CLOSED – minimal sufficient authoring

La completezza architetturale, funzionale o di lifecycle non è una preconditione all'analisi. Una successiva analisi può scoprire gap documentali e farli rientrare nel ciclo di authoring e governance.

2 Sequenza di authoring



La Macro Project Map review non è un nuovo tipo di documento L1 e non crea un ulteriore livello gerarchico: è un passo di validazione dell'insieme di MR prima di costruire i branch downstream.

3 Step 0 – frame the project problem

Domanda

Quale problema generale o classe di problemi deve affrontare il progetto se rimuoviamo temporaneamente le scelte di soluzione correnti?

Regole

- descrivere problema e boundary, non l'architettura scelta;
- rimuovere provider, device, database, framework, algoritmo e protocollo se non sono intrinseci al problema;

- dichiarare responsabilità importanti fuori scope;
- usare il framing per verificare copertura e overlap degli MR;
- non copiare il framing dentro ogni MR.

4 MacroRequirement authoring

Domanda

Nel problema già inquadrato, quale responsabilità macro stabile e autonomamente significativa stiamo governando, quale risultato o valore macro contribuisce, perché conta e chi coinvolge?

4.1 Semantica del corpo

Elemento	Funzione
Title	nome conciso comprensibile nel dominio
Intent	scopo, valore e risultato macro desiderato
Context	background minimo per interpretare la responsabilità
Stakeholders	ruoli materialmente beneficiari, impattati o governanti
Scope	confine semantico della responsabilità macro
Assumptions/ Constraints	opzionali, solo se valgono per l'intero branch
dependsOn MR	dipendenza macro genuina, non pseudo-gerarchia

4.2 Review tests

- problem anchoring;
- single macro responsibility;
- architecture resilience e temporal stability;
- solution-removal;
- stakeholder readability;
- nessuna obbligazione atomica da FR;
- dependency-vs-containment;
- teachability / Macro Project Map usefulness;
- analysis enabling, not analysis producing.

4.3 Isolated-MR review

Dopo la prima decomposizione costruire il grafo degli MR usando le sole relazioni canoniche `dependsOn`. Per ogni nodo a grado zero:

$$\deg(m) = \deg^-(m) + \deg^+(m) = 0$$

il metodo richiede *review*, non invalidazione automatica.

CANDIDATE – Isolated-MR review

Un MacroRequirement senza relazioni canoniche con altri MR non è invalido. Deve però essere riesaminato esplicitamente. Se il suo contenuto dichiara un concern trasversale o i discendenti previsti risultano prevalentemente proprietà/constraint su comportamenti posseduti da altri branch, l'isolamento è evidenza di possibile errata classificazione come MR.

Domande di review

1. Se rimuoviamo questo MR, scompare una responsabilità/capability macro del progetto oppure restano le capability e scompaiono soprattutto proprietà specializzate?
2. Il suo scope parla prevalentemente di dati, risultati o comportamenti posseduti da altri branch?
3. I discendenti plausibili sarebbero soprattutto security/privacy/performance/compliance constraints su FR altrui?
4. Esiste invece una dipendenza macro genuina che non è stata documentata?
5. L'MR è stato creato principalmente per “dare una casa” a una metodologia o a una categoria di analisi?

Non trasformare l'heuristic in una falsa invariante

Un MR isolato può essere perfettamente valido quando possiede una responsabilità macro autonoma. Il tool può segnalare **REVIEW REQUIRED**; non deve produrre **INVALID MR** sulla sola base del grado del nodo.

4.4 Regression example – facial access

Il corpus storico conteneva un MR autonomo denominato “Uso responsabile dei dati biometrici e delle decisioni automatiche”. Il nodo era isolato, mentre il suo contenuto descriveva proprietà trasversali di dati e risultati prodotti negli altri branch. La regressione ha mostrato che la rimozione del nodo non elimina le tre responsabilità macro del progetto: accesso controllato, gestione delle persone autorizzate e riconoscimento facciale.

I contenuti utili vengono riclassificati per natura: la limitazione di finalità dei dati biometrici è candidata a obbligazione specializzata locale sui FR applicabili; la contestabilità/review degli esiti automatici contiene invece una responsabilità operativa autonoma e viene spostata nel branch che governa il processo di accesso come Decision + FR. La lezione non è “gli MR isolati sono sbagliati”, ma “un concern trasversale non deve essere promosso a MR solo per renderlo visibile all'analisi”.

5 Decision authoring**Domanda**

Quale commitment significativo restringe questo MR, perché il progetto assume questa posizione e quali conseguenze accettiamo?

Corpo minimo: Title, Context, Decision, Consequences.

5.1 Responsibility-boundary question

Prima degli FR chiedere esplicitamente:

Il progetto implementa/possiede questa responsabilità oppure consuma una capability esterna, di provider o organizzativa?

Il cambio di boundary può far emergere o scomparire interi FR branch. Un servizio esterno consumato non diventa responsabilità funzionale interna soltanto perché è necessario al sistema.

5.2 Necessity/default Decision

Se non emerge una alternativa materialmente distinta, non saltare automaticamente il layer Decision. Una necessity/default Decision è ammessa solo dopo review e solo quando Context spiega perché lo spazio ammissibile è singleton o non materialmente differenziato; Consequences devono restare materiali e la Decision deve essere riapribile.

6 FunctionalRequirement authoring

Domanda

Data la Decision parent e una condizione/input applicabile, quale subject/capability deve compiere quale azione funzionale su/con quale oggetto o informazione, e quale risultato osservabile o failure behavior deve conseguire?

6.1 Regole chiuse

- esattamente una Decision parent;
- MR owner derivato dal parent Decision, senza seconda ownership;
- comportamento operativo e indipendentemente valutabile;
- un solo unità coerente; responsabilità indipendentemente modificabili vanno separate;
- implementation independence;
- prosa normativa primaria, riferimenti SPO di supporto;
- nessuna Decision sotto FR;
- service consumption non crea co-ownership;
- realization ed evidence sono separati dalla semantica del requisito.

6.2 Normative prose e SPO

Pattern indicativo:

```
[Condition,] <Subject> MUST <Predicate> <Object>
[qualifier / observable result / failure behavior].
```

La tripla non sostituisce la clausola. Condizioni, correlation, atomicity, lifecycle e failure semantics restano nella prosa normativa.

6.3 Parameter classification

Non introdurre un generico `functionalParameters`. Classificare il valore per semantica: strategia o medium significativo → Decision; target latency/throughput → futura specializzazione performance/quality; retention → governance/privacy/regulatory concern; provider API limit → contract candidate; tuning incidentale → realization/configuration.

7 SpecializedRequirement authoring – S1 CLOSED

CLOSED – definizione

Uno `SpecializedRequirement` è una specializzazione normativa governata di un singolo `FunctionalRequirement` che rafforza le condizioni sotto le quali il parent FR è considerato soddisfatto, imponendo una obbligazione concern-specific che vale insieme all'obbligazione funzionale e non al suo posto.

Domanda

Quale obbligazione concern-specific aggiuntiva deve valere insieme alla funzione affinché il parent FR sia considerato soddisfatto, senza ridefinirne la funzione né scegliere come realizzarla?

7.1 Core semantico minimo

```
SpecializedRequirement [abstract]
  parentFunctionalRequirement : FunctionalRequirement [1]
  normativeObligation         : [1]
```

Ogni FR può possedere zero o più SR. Per gli SR applicabili:

$$Effective(F) = F \wedge S_1 \wedge \dots \wedge S_n.$$

Non esiste semantica implicita di override o “last wins”.

7.2 Removal, correctness e autonomy tests

Removal test. Tolto lo SR, la funzione del parent FR deve restare semanticamente riconoscibile; deve scomparire la proprietà specializzata.

Functional-correctness test. Una condizione necessaria alla normale correttezza della funzione resta nell'FR anche se può avere rilevanza di sicurezza o compliance.

Subordinate-action test. Uno SR può richiedere una azione positiva aggiuntiva se trigger e risultato sono subordinati alla soddisfazione del parent FR.

Autonomy test. Se il comportamento aggiuntivo possiede scopo, trigger, risultato o consumer significativi indipendentemente dal parent FR, deve essere valutato come FR autonomo.

Mechanism-removal test. Se eliminando un nome di tecnologia/meccanismo resta una proprietà normativa chiara, la proprietà può essere SR e il meccanismo resta Decision/realization.

7.3 Shared concern non significa multi-parent SR

Lo stesso concern può applicarsi a FR diversi, anche appartenenti a branch e momenti differenti del sistema. Ciò non rende il singolo SR multi-parent. Una futura fonte normativa condivisa o un meccanismo di reuse può evitare copy/paste, ma non deve essere anticipato nel core finché un controesempio non lo richiede.

CANDIDATE – concern-bucket avoidance

Security, privacy, performance o compliance non richiedono MacroRequirement dedicati per diventare analizzabili. Quando un concern rafforza le condizioni di soddisfazione di comportamenti già governati, il junction naturale è SpecializedRequirement e la relativa specializzazione concreta. Una vera responsabilità macro autonoma rimane invece un legittimo MR anche se appartiene allo stesso dominio di concern.

8 Cross-branch composition e effective context

Un FR può consumare una capability governata da un altro MR senza co-ownership. Il target canonico della relazione di consumption resta deferred alla Base Analysis. Inoltre parentage e service composition non esauriscono tutto il contesto governato che può influenzare un requisito: Decision sibling, policy o rappresentazioni governate possono richiedere review senza diventare parent. Il meccanismo formale di *effective governed context* resta OPEN e non giustifica oggi una relazione generica **affects**.

9 End-to-end review checklist

1. Frame the problem.
2. Decompose into MR by stable macro responsibility.
3. Build/review the Macro Project Map: overlap, dependencies, isolated nodes.
4. For each isolated node distinguish autonomous MR, missing dependency, or concern bucket.
5. Expose significant Decisions, especially responsibility boundaries.
6. Write operational FRs with observable/failure semantics.
7. Reuse governed references; do not let SPO replace normative prose.
8. Review cross-branch service consumption without co-ownership.
9. Add SRs locally where a concern strengthens an FR.
10. Keep implementation controls, verification evidence and analysis provenance out of the SR core.
11. On change, trigger transitive review; do not presume preservation or automatic invalidity.

10 Tool assistance

Il tool può:

- visualizzare la gerarchia e le relazioni **dependsOn**;

- costruire la Macro Project Map e segnalare nodi a grado zero come REVIEW REQUIRED;
- proporre le domande dell’Isolated-MR review, senza riclassificare automaticamente;
- suggerire riferimenti già esistenti e prevenire duplicazione accidentale;
- validare parentage, cardinalità e coerenza strutturale;
- mostrare SR locali e, in futuro, eventuale reuse di fonti normative.

Il tool non deve inferire da similarity, termini security/privacy o posizione nel grafo che un MR sia invalido, né creare semantica canonica senza review governata.

11 Status

Stato	Elementi
CLOSED	hierarchy MR→Decision→FR→SR; one Decision parent per FR; one FR parent per SR; normative strengthening; conjunctive SR composition; functional/autonomy boundaries; realization separation; minimal sufficient authoring.
CANDIDATE	Isolated-MR review come heuristic graph-assisted; concern-bucket avoidance come regola di authoring derivata dalla regressione MR-0004.
OPEN	shared normative source/reuse; effective governed context; explicit sibling-Decision impact; lifecycle/supersession details; target canonico service consumption.
DEFERRED	SecurityRequirement-specific fields; Finding/provenance; Base Analysis/BAE; STRIDE/STRIDE-AI; controls; formal Policy/Rule/NormativeSource; ThreatForge conformance.

12 Reopen rule

Il contratto può essere riaperto soltanto da un controesempio concreto che non sia rappresentabile senza rompere le invarianti correnti. Una segnalazione graph-assisted che produce falsi positivi non riapre automaticamente il metamodello MR: può richiedere solo la revisione dell’heuristic o della sua implementazione.

A Traceability

Questa R3 deriva dal contratto R2 03-functional-requirement/02-authoring-guidance/DDTA_AUTHORING_RULES_THROUGH_FR_R2.md, dal capitolo thesis/latex/chapters/04-documentation-authoring-metamodel.tex, dal corpus facial-access storico e dalla formalizzazione S1 di SpecializedRequirement prodotta nella fase corrente. Baseline repository: nballestriero/documentation-driven-threat-analysis; commit: 3eeac1fc972d89282cd2ffd8700e9af0f5b69610.